

Why is Host Integrity Monitoring Important?

Thanks to the recent government regulations and the general public's concern for information security, file integrity monitoring systems are generating a lot of interest. We take a look at the basic concepts behind file integrity monitoring systems and list the reasons for using them.



Imagine getting back to your house after a well-deserved vacation and realising your house has been burgled. What is the next step you would take?

Anybody would want to check what items have been stolen so that the next step like calling the police and detailing the items lost in the FIR can be taken. This is exactly what a file integrity monitoring system would do. But first, let's discuss some basic business drivers that mandate such software. Information security is a term that features prominently in the most sacred of all business documents—'Contracts & Agreements'.

Nowadays, almost every contract or agreement that a business organisation signs has an information security related clause incorporated in it. This does not refer to the standard, 'Thou shalt not disclose my information to anyone else...' and other such hyperbole. It is also called the NDA, or Non-Disclosure Agreement, many of which carry such a broad definition of the term 'confidential information' that almost the entire information entailed in a project could come under it. Proper clauses mandate appropriate measures from the vendor to ensure that the organisation's data remains secure during the engagement. In some cases, industry bodies have come up with regulations, e.g., PCI-DSS, whereas in other cases, standards bodies like ISO have evolved their own standards (like ISO 27001:2005), which are widely accepted. To top it all, the governments of various countries have also

passed some laws related to information security, e.g., the EU Privacy Acts, the UK Data Protection Act, the HIPAA, GLBA and SOX (USA), the IT Act 2008 in India, etc, which, unlike the standards and regulations mentioned earlier, are acts of law and are not optional.



Note: Industry standards and government regulations have been constant drivers for the implementation of a file integrity monitoring system.

Now, all of the above-mentioned fear-evoking TLA (Three Letter Acronyms) have some things in common, related to the topic of our discussion:

1. All of them mandate some type of monitoring to detect and to respond to anomalies detected, including logging and monitoring.
 2. Some of them, like PCI-DSS in particular, mandate an integrity monitoring system. PCI DSS section No 11.5 requires deployment of file integrity monitoring software to alert personnel to unauthorised modification of critical system files.
 3. Many organisations also desire to implement such systems in order to respond to a security incident as soon as it happens as a part of organisational due diligence.
- Integrity refers to the property of wholeness. For example, a bottle is usually defined or visualised with a cap; which